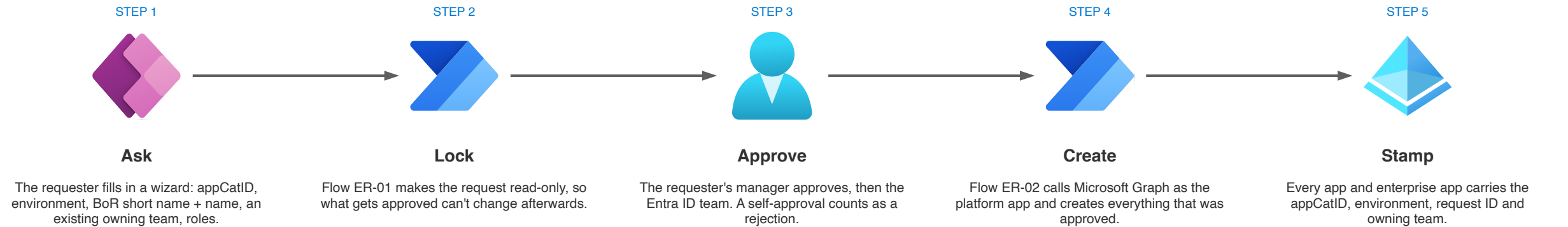


Entra self-service on Power Platform — at a glance

A team asks for an app registration in a Power App; two people approve; a flow creates it in Entra ID.



Where things live

Power Apps canvas app · SharePoint site /teams/m365automationqa (4 lists) · 4 Power Automate flows · 1 Entra app registration with a certificate

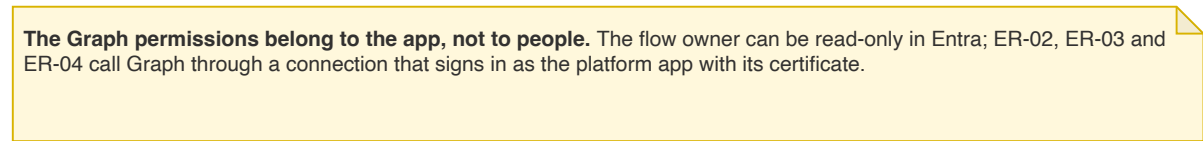
Licences

App and ER-01 use Standard connectors (covered by Microsoft 365). ER-02, ER-03 and ER-04 use a Premium connector: one Power Automate Premium licence for the flow owner.

Nobody gets Entra admin rights. Requesters, managers and even the flow owner can be read-only in Entra. Only the platform app registration holds Graph permissions, and only the flows can use it.

Two approvals, one snapshot. Approvers see a summary of the locked snapshot (ApprovedPayloadJson), and ER-02 executes only that snapshot, never the editable copy.

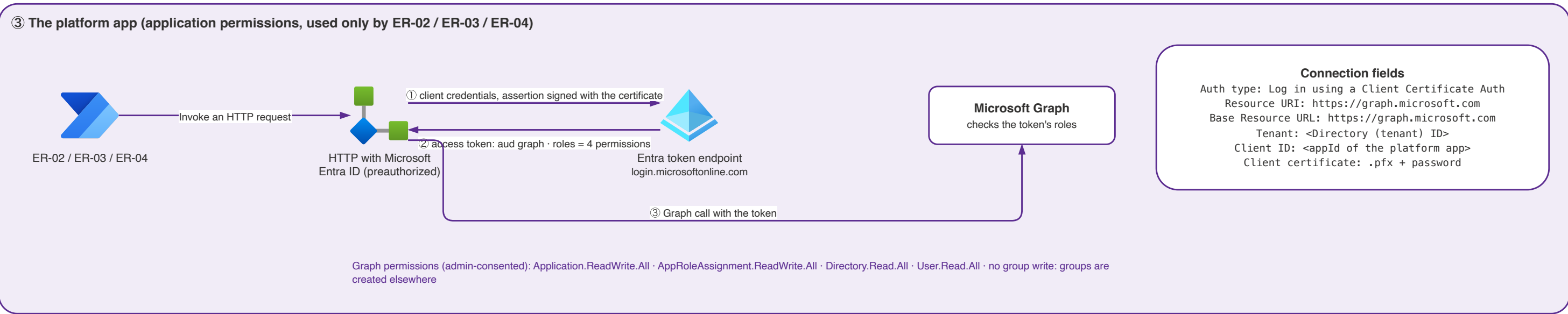
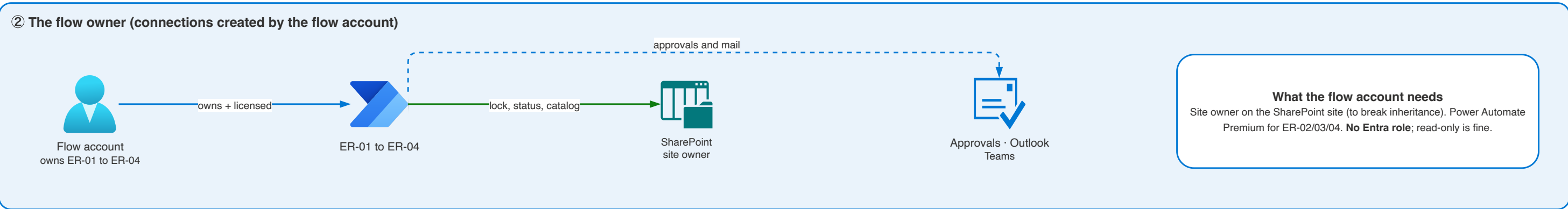
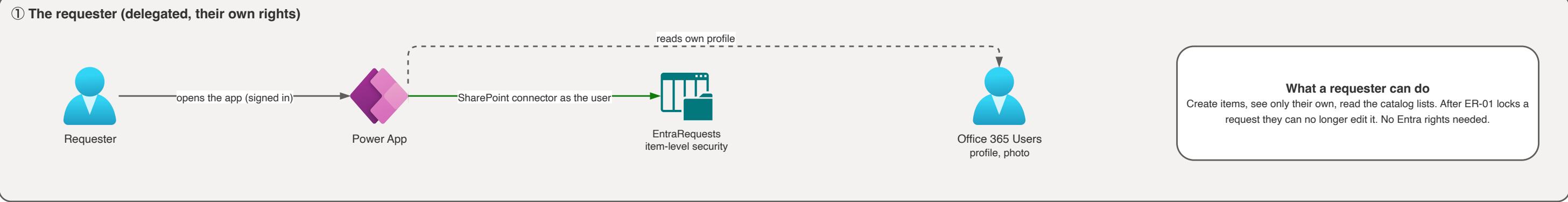
People on the left, the Power Platform environment in the middle, Entra ID on the right. Everything is in one Entra tenant.



Anyone who can edit ER-02, ER-03 or ER-04 can use that connection. Keep the flows in their own environment, with only the Entra ID team as co-owners.

Identity — who each call runs as

Three kinds of identity. Only the third one can change Entra ID.

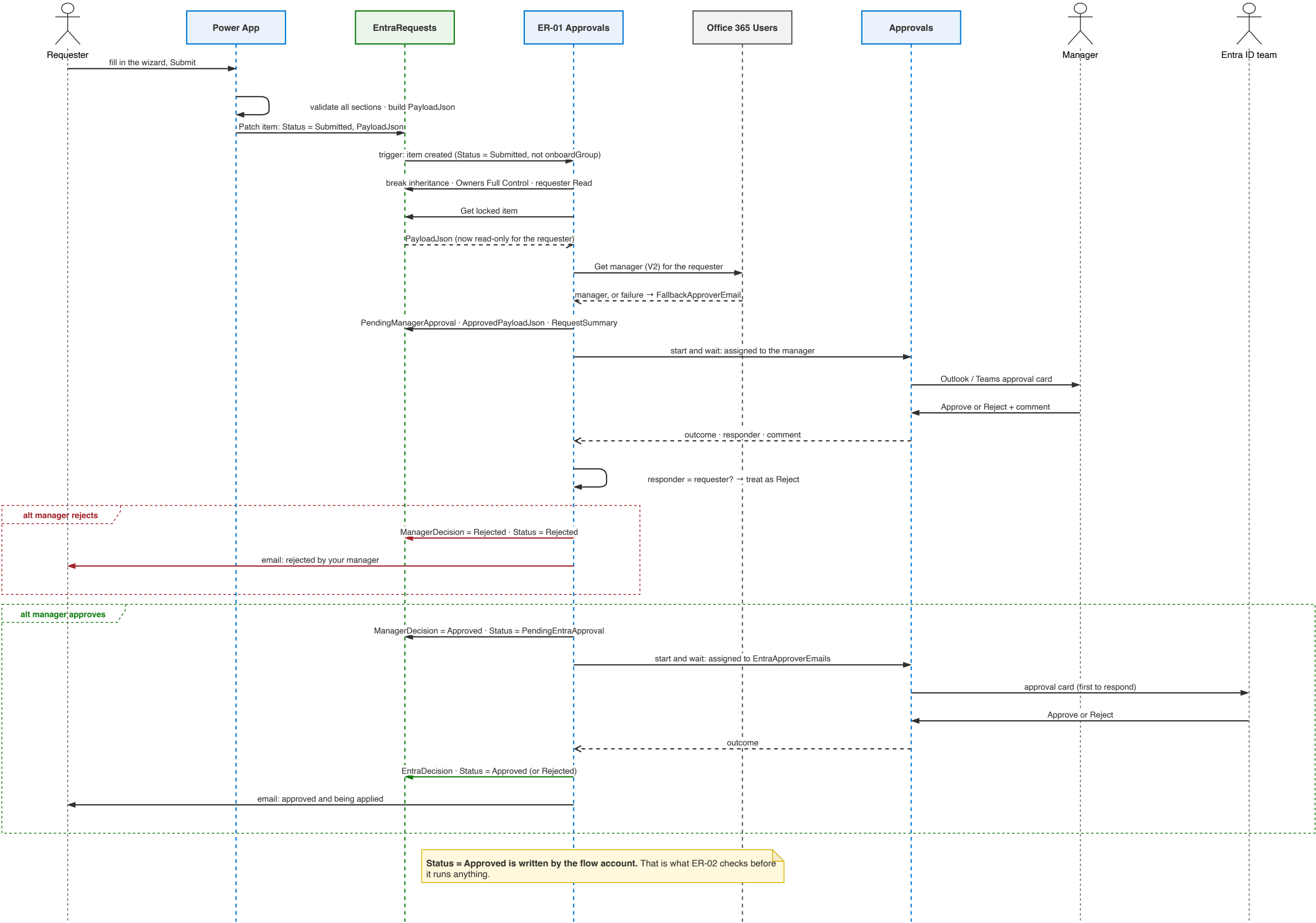


Don't pick 'Log in with Microsoft Entra ID' on the connection: that calls Graph as the flow account, and a read-only account gets *Insufficient privileges*.

The certificate stays inside the connection. Flow editors can use it but can't read it; run history never shows it.

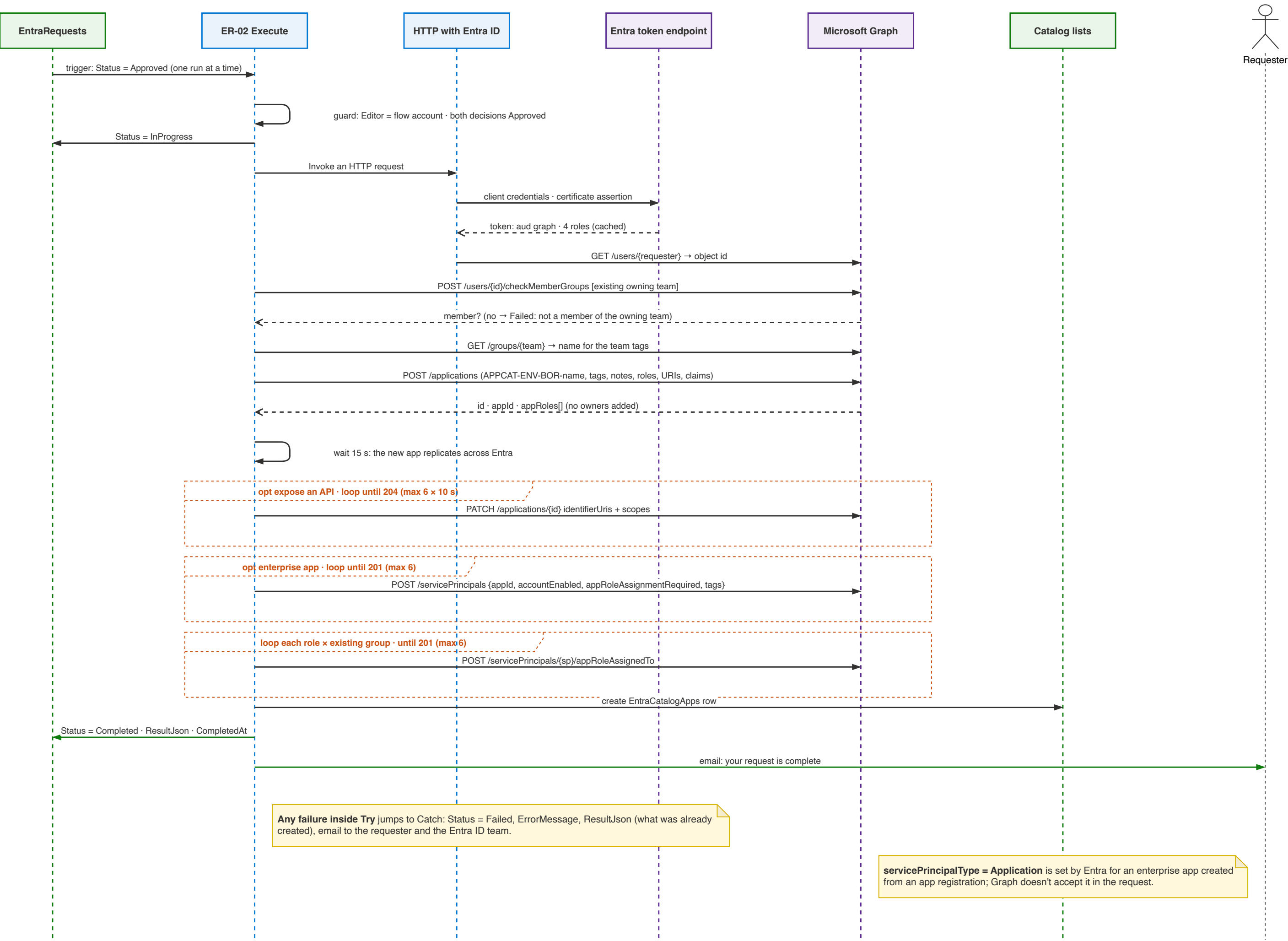
Sequence — submit and approve (ER-01)

From the Submit button to Status = Approved, including both ways a request is rejected.



Sequence — ER-02 creates an app registration

Every Graph call goes through the client-certificate connection; the token is fetched once and reused.

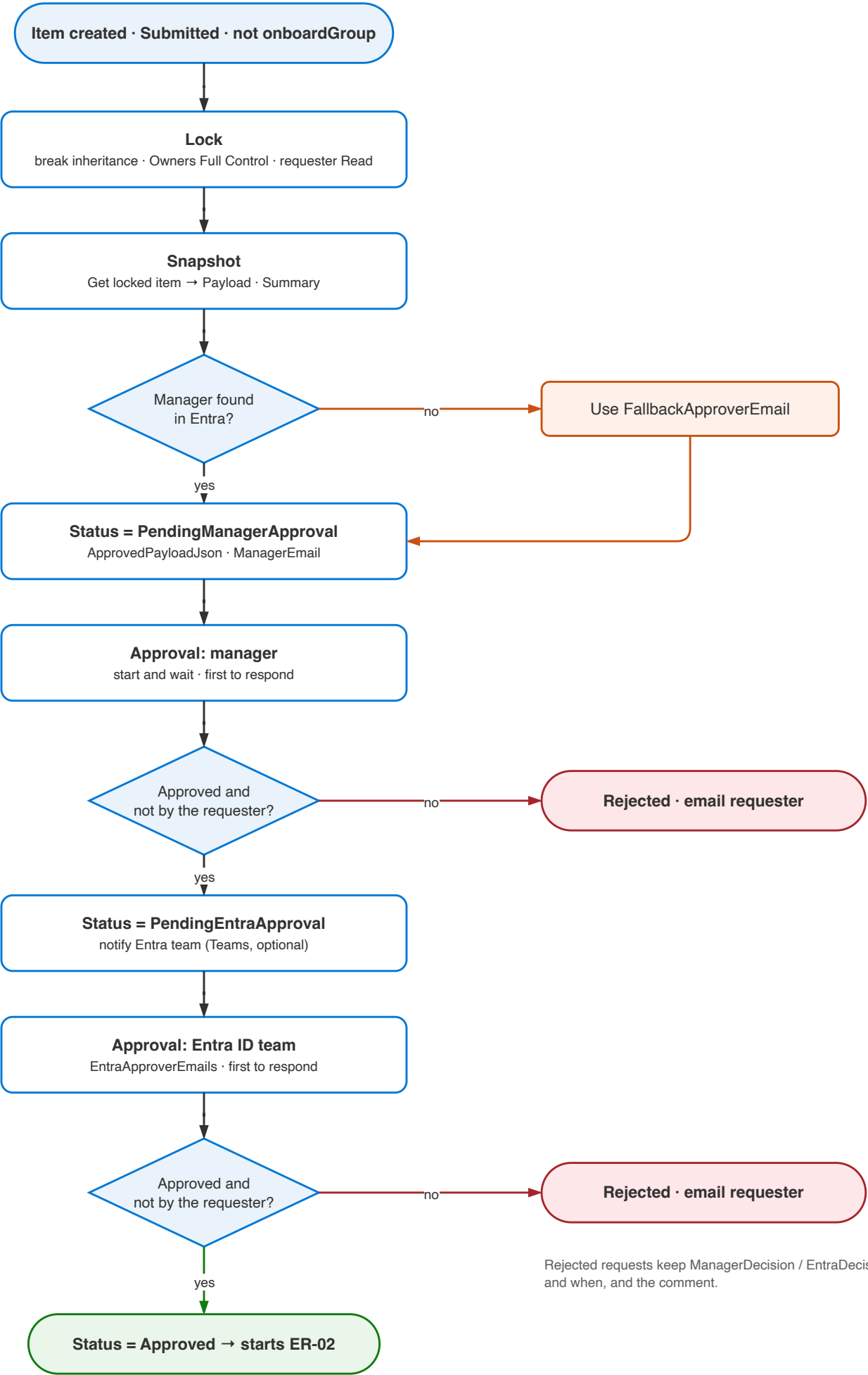


Flowchart — ER-01 Approvals

Standard connectors only. Every rejection exits to the right; the approved path runs straight down.

Why lock before snapshot. The requester can edit the item until step 1 runs. Reading PayloadJson again after the lock gives a copy nobody but site owners can change.

Self-approval rule. If the responder's email equals the requester's, the outcome is Reject, even if they clicked Approve.



Rejected requests keep ManagerDecision / EntraDecision, who and when, and the comment.

Flowchart — ER-02 Execute

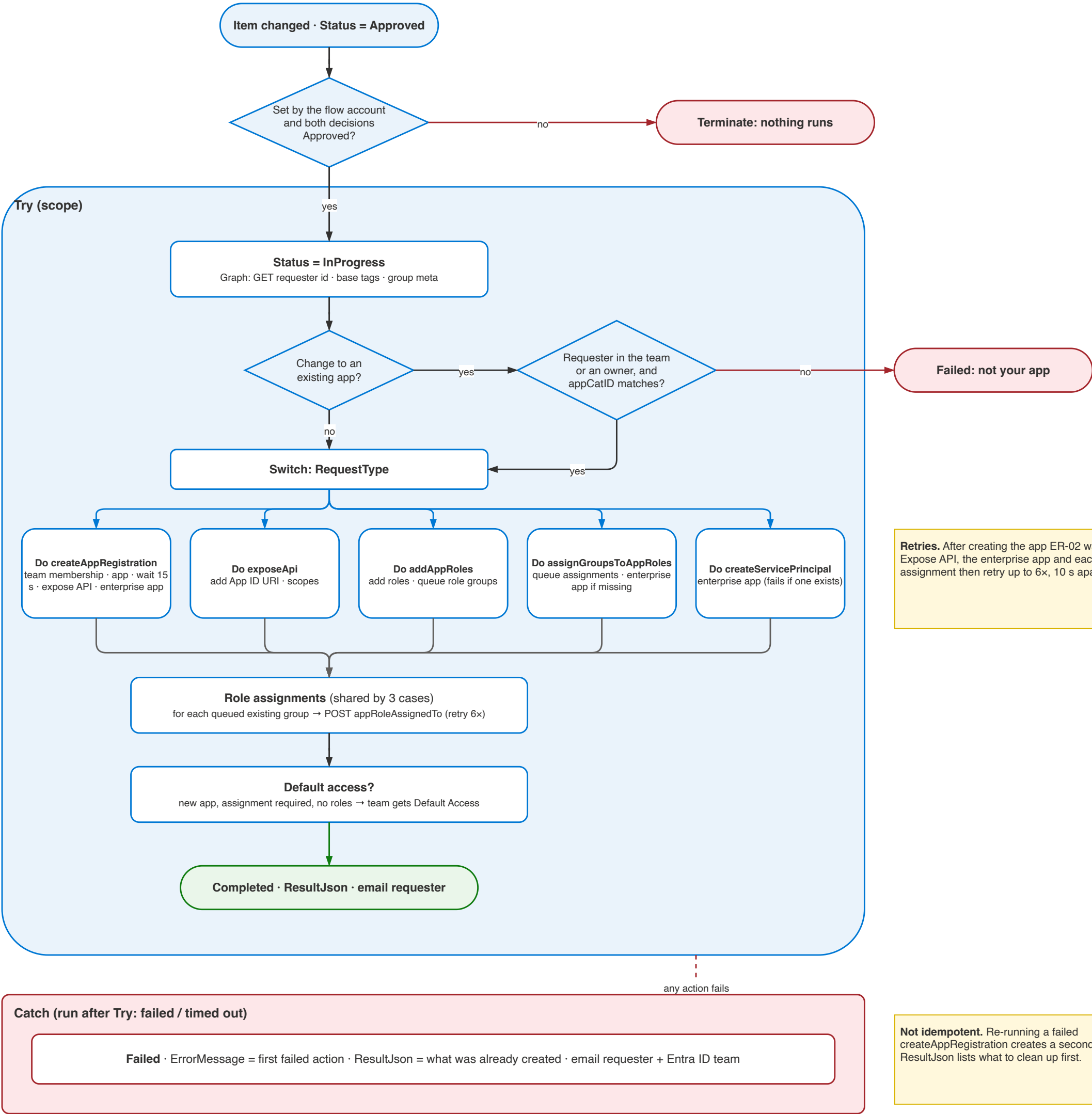
Premium. Runs one request at a time. Guards first, then one scope per request type, then role assignments.

Why the guard. A site owner editing Status by hand is not the flow account, so the run stops before any Graph call.

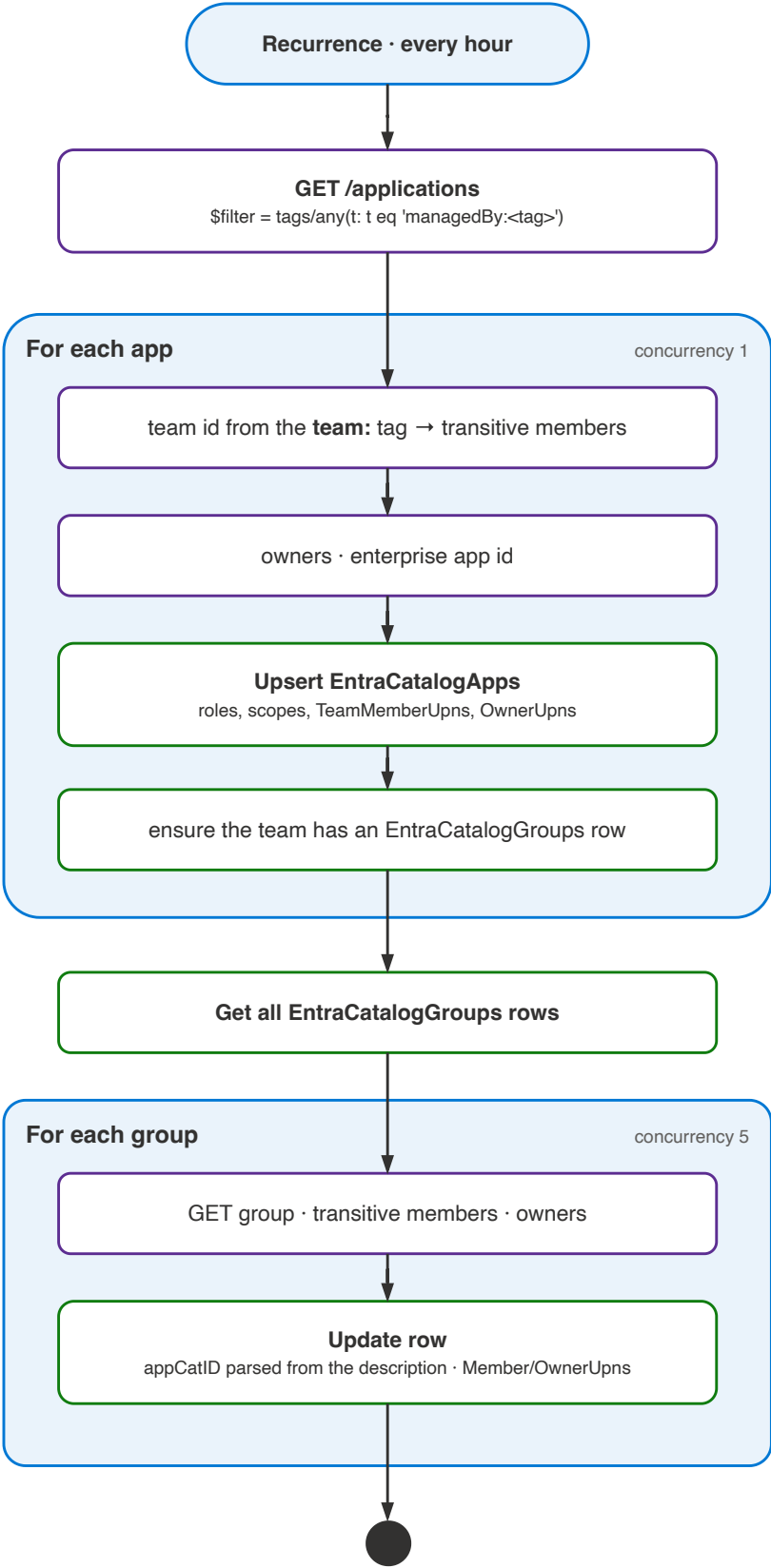
No groups, no owners. Groups must already exist (onboarded with ER-04). The app registration and enterprise app get no owners.

Retries. After creating the app ER-02 waits 15 s; Expose API, the enterprise app and each role assignment then retry up to 6x, 10 s apart.

Not idempotent. Re-running a failed createAppRegistration creates a second app; ResultJson lists what to clean up first.



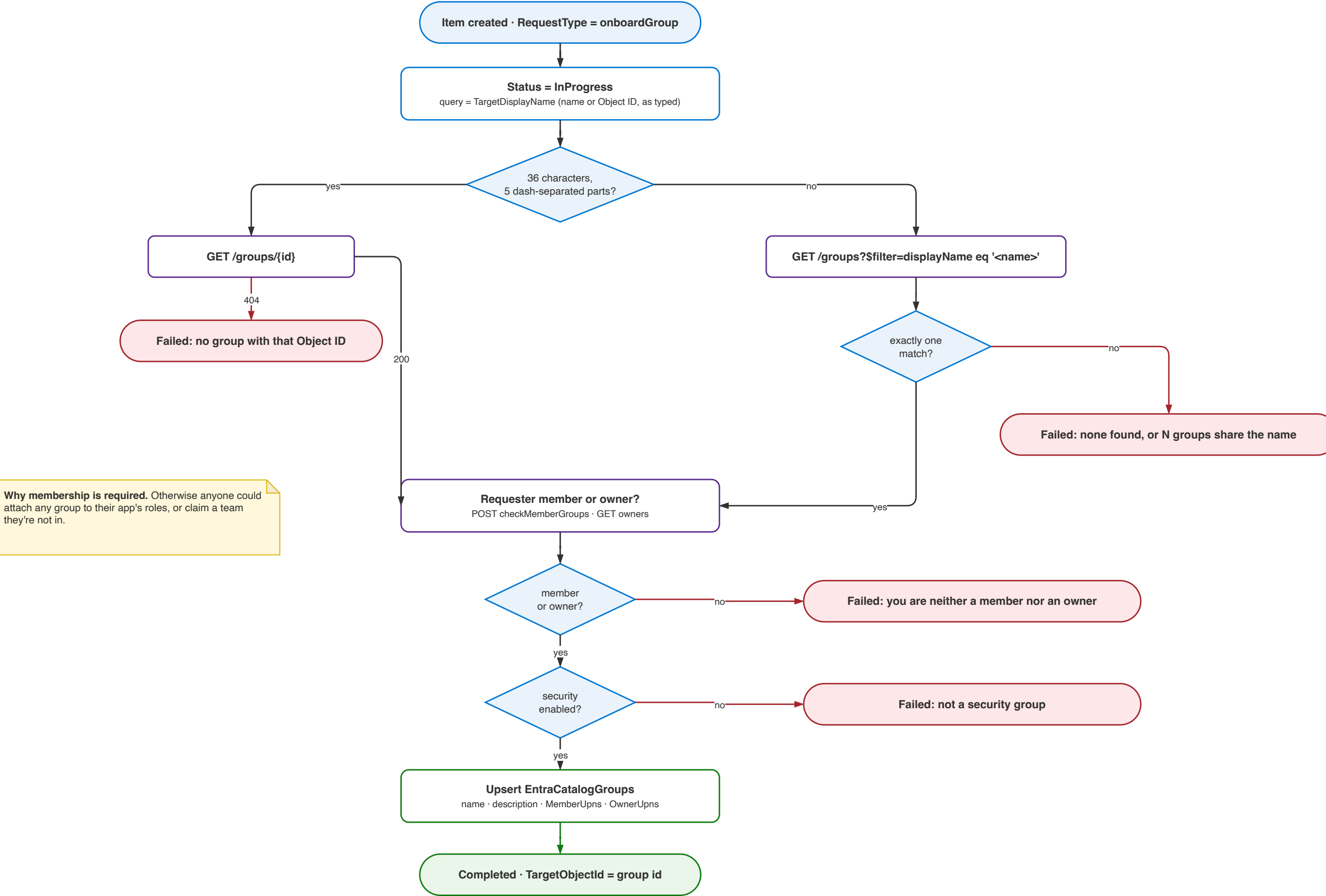
Flowchart — ER-03 Catalog sync
Hourly. Reads Entra ID, writes the two catalog lists the app uses for its pickers. Never changes Entra.



UPN lists format
;alex@contoso.com;sam@contoso.com;
lower case, ',' at both ends, so the app can test ";" & upn & ";" in TeamMemberUpns

Onboarding an existing group is done by ER-04 (*Add existing group* in the app). ER-03 then keeps that row's members and owners current every hour.

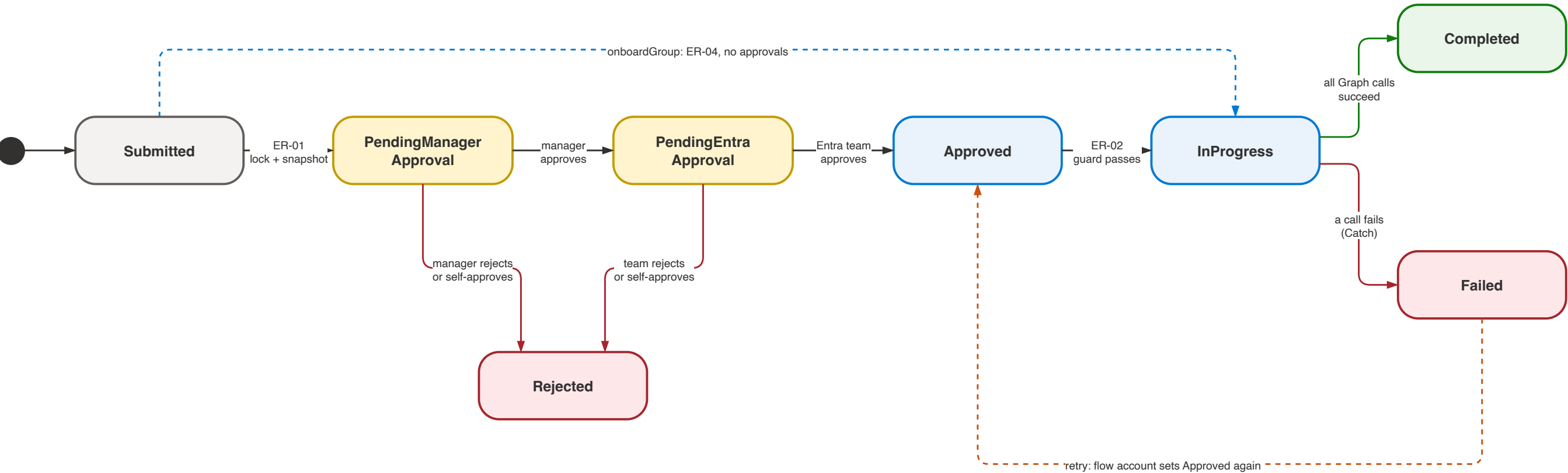
Deleted group? GET returns 404 and that iteration fails. Add a branch with run-after 'has failed' to flag or delete the row.



Why membership is required. Otherwise anyone could attach any group to their app's roles, or claim a team they're not in.

Request lifecycle — EntraRequests.Status

Transitions name who makes them. Only the flow account moves a request past Submitted.

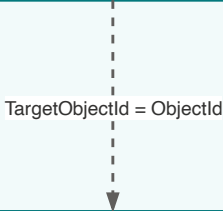


Who writes Status	
Requester (Power App)	 Submitted
ER-01 (flow account)	 PendingManagerApproval, PendingEntraApproval, Approved, Rejected
ER-02 (flow account)	 InProgress, Completed, Failed
ER-04 (flow account)	 InProgress, Completed, Failed (onboardGroup only)
Site owners	 can edit, but ER-02 ignores edits not made by the flow account

Versioning is the audit trail. EntraRequests keeps 500 versions, so every status change, decision and who made it is recorded on the item.

SharePoint site /teams/m365automationqa

EntraRequests · one item per request
Title: REQ-2610-K7M4X2 (request id, indexed)
RequestType: choice, 6 types · Status: choice, 8 states
AppCatId · TargetDisplayName · TargetObjectId (change requests)
Justification · TicketReference
PayloadJson: written by the app (editable until ER-01 locks)
ApprovedPayloadJson: snapshot after the lock, the only thing ER-02 runs
RequestSummary: text approvers see
ManagerEmail, ManagerName · ManagerDecision (choice) · ...By · ...At · ...Comment
EntraDecision (choice) · EntraDecisionBy · EntraDecisionAt · EntraComment
ResultJson: ids created · ErrorMessage · CompletedAt
Created By (built in): the requester, can't be faked



EntraCatalogApps · written by ER-02 / ER-03
Title · ObjectId · AppId · AppCatId
TeamGroupId · TeamGroupName (from team: / teamName: tags)
ServicePrincipalId · IdentifierUri
AppRolesJson · ScopesJson
TeamMemberUpns · OwnerUpns (;upn;upn;)
LastSynced

EntraCatalogGroups · written by ER-04 / ER-03
Title · GroupId · AppCatId (from description)
Description
OwnerUpns · MemberUpns (;upn;upn;)
LastSynced

EntraSettings · exactly one item (ID 1)
TenantId · GraphClientId · ManagedByTag
ServiceAccountUpn (lower case, checked by ER-02)
EntraApproverEmails · FallbackApproverEmail
KeyVaultName · PfxSecretName · PfxPasswordSecretName (plain HTTP option only)
PowerAppUrl (link in approval cards)

Permissions

EntraRequests: item-level (read/edit own), then ER-01 locks each item:
Owners Full Control, requester Read.

Catalog lists: members Read.
EntraSettings: owners only.

PayloadJson · createAppRegistration

payload
displayName = APPCAT-ENV-BORSHORT-freeText
appEnv (P Q D L U F T S) · borShortName · nameText
description · signInAudience
owningGroup { mode: existing, id, displayName }
redirectUriWeb · redirectUriSpa (';' separated)
exposeApi { enabled, identifierUriTemplate, scopes[] }
optionalClaimsIdToken · optionalClaimsAccessToken · groupMembershipClaims
appRoles[] { value, displayName, description, allowedMemberTypes,
assignGroups[] { mode: existing, id, displayName } }
createServicePrincipal · appRoleAssignmentRequired · tags

Other types: exposeApi, addAppRoles, assignGroupsToAppRoles, createServicePrincipal, onboardGroup (see docs/03 §3.5). No owners field. No field identifies the requester; the flows use Created By.

Stamped on every object Entra creates

app registration · tags
appCatID:<id> · appEnv:<P Q D L U F T S> · borShortName:<x>
team:<group id> · teamName:<name>
createdBy:<upn> · createdById:<oid> · createdTimestamp
lastUpdatedBy · lastUpdatedTimestamp · requestId:REQ-...
managedBy:<ManagedByTag> · optional key:value tags

app registration · notes
appCatID=...; requestId=...; createdBy=...; managedBy=...

enterprise app (service principal)
appId = the new app · accountEnabled = true
appRoleAssignmentRequired = from the request
tags = app tags + WindowsAzureActiveDirectoryIntegratedApp

No owners on either object. ER-03 finds managed apps by the managedBy tag.

Security — who can do what, and the guards in the flows

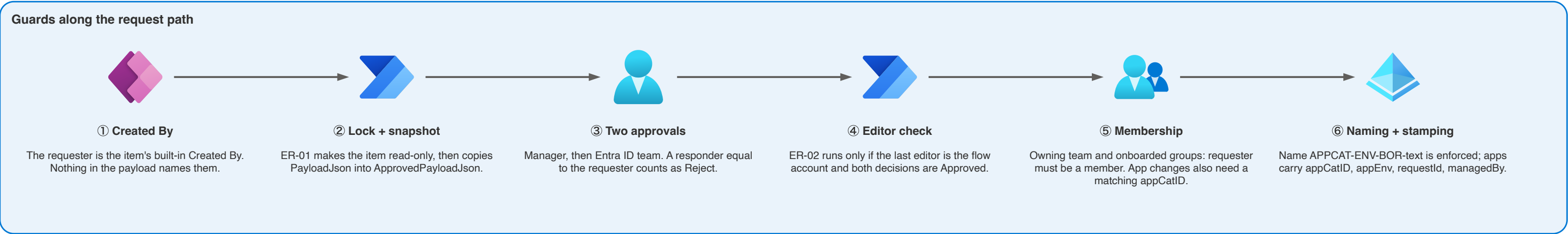
Least privilege for people; one tightly held app identity for Graph.

People and their access
Requester: SharePoint Member · uses the app · no Entra role
Manager: answers approvals only (Outlook / Teams)
Entra ID team: second approval · site Owner · flow co-owners
Flow account: owns ER-01 to ER-04 · site Owner · Power Automate Premium · Entra read-only
Entra admin: one-time admin consent for the platform app
Power Platform admin: environment, DLP policy, Dataverse for Approvals

Platform app · Microsoft Graph application permissions
Application.ReadWrite.All: app registrations, enterprise apps, URIs, scopes, roles, tags
AppRoleAssignment.ReadWrite.All: assign existing groups to app roles
Directory.Read.All: find groups by name or id, checkMemberGroups, members and owners
User.Read.All: requester object id
No group write permission: groups are created outside this platform
Credential: certificate only (no client secret) · admin consent required

SharePoint permissions
Site Owners: Entra ID team + flow account (Full Control)
Site Members: everyone who may raise requests (Edit)
EntraRequests: item-level · read and edit own items only
Each request after ER-01: inheritance broken · Owners Full Control · requester Read
Catalog lists: Members Read · EntraSettings: Owners only

Power Platform governance
Dedicated environment 'Entra Self-Service' · makers = Entra ID team only
DLP: SharePoint, Approvals, Office 365 Users, Outlook, Teams, HTTP with Entra ID (+ HTTP, Key Vault)
App shared as User (never Co-owner) · flows: Entra ID team as co-owners only
Connection 'HTTP with Entra ID' (cert) owned by the flow account, not shared further



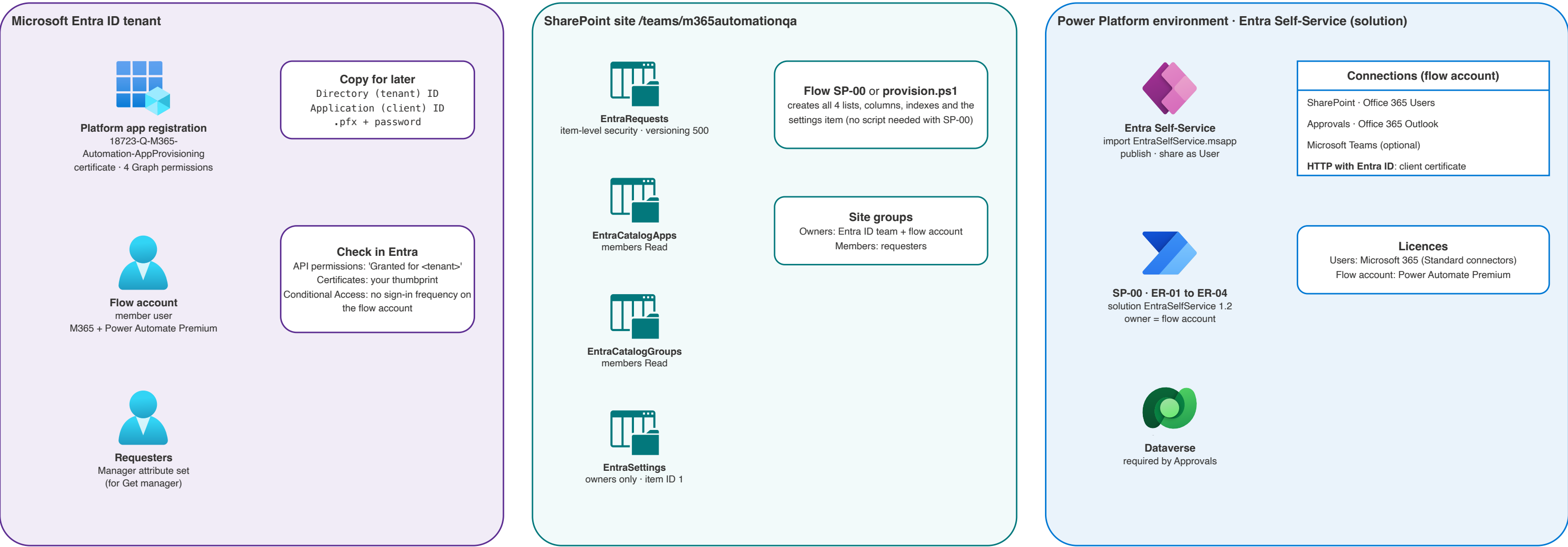
The one real risk. Whoever can edit ER-02, ER-03 or ER-04 can make any Graph call the platform app is allowed to make. Treat flow co-ownership like an Entra admin role.

Rotate the certificate yearly. Upload the new one to the app registration, update the connection, then remove the old one. If other automations share the app, give this solution its own certificate.

Audit: EntraRequests versions, flow run history, Entra audit log (initiated by the platform app).

Deployment — what exists, and the order to build it

Three places to configure: Entra ID, the SharePoint site, and the Power Platform environment.



- Build order**

 - 1 **Entra admin:** app registration, upload the .crt, add 4 permissions, grant admin consent (docs/01)
 - 2 **Flow account:** import the solution zip, create the 5 connections, set the site URL (docs/09)
 - 3 Run SP-00 (or provision.ps1) to create the lists; fill the EntraSettings item (docs/02)
 - 4 **Power Apps:** import the .msapp, add the data sources, publish, share (docs/03)
 - 5 Copy the app's web link into EntraSettings.PowerAppUrl
 - 6 Turn on ER-01, ER-03, ER-04; onboard the first groups with *Add existing group*
 - 7 Turn on ER-02 and test one request per type (docs/06 to docs/10)
- Test the Graph connection first.** In a scratch flow: Invoke an HTTP request GET /v1.0/organization. A 403 means consent is missing; AADSTS700027 means the certificate doesn't match.
- Move to production** by exporting the solution; connections are re-created in the target environment.

Option — how ER-02 / ER-03 authenticate to Graph
Both use the same app registration and certificate. They differ in where the certificate lives.



A · HTTP with Microsoft Entra ID (preauthorized)
Connector: HTTP with Microsoft Entra ID (preauthorized), Premium
Auth type: Log in using a Client Certificate Auth
Certificate: uploaded once into the connection
Each Graph call: Invoke an HTTP request, relative URL /v1.0/...
Extra connectors: none
Response body arrives as text: wrap in json() if fields come back empty
Limit: 100 calls per minute per connection
Fails as: connection error at save time if tenant / client ID / cert are wrong

Identical either way
App registration 18723-Q-M365-Automation-AppProvisioning
Same 4 Graph application permissions + admin consent
Same certificate (.pfx for Power Automate, .crt in Entra)
Same Graph requests and JSON bodies (powerautomate/actions)
Same Premium licence for the flow owner
Same risk: flow editors can use the identity
ER-01, the app and SharePoint: unchanged

B · HTTP action + Azure Key Vault
Connector: HTTP (built in), Premium
Auth: Active Directory OAuth · Credential Type = Certificate
Certificate: Key Vault secrets (base64 .pfx + password)
Each flow: Get PFX + Get PFX password (secure outputs) first
Extra: Azure subscription, Key Vault, Key Vault Secrets User role
Authentication set on every HTTP action
Limit: no connector throttle to worry about
Fails as: 401 at run time if the secret or password is wrong

Pick A unless you already run Key Vault for Power Platform secrets, or you need one certificate shared across many flows and environments with central rotation.

Not options: 'HTTP With Microsoft Entra ID' (v2), the Microsoft Entra ID connector and the App Registrations connector all act as the signed-in user, or are read-only.